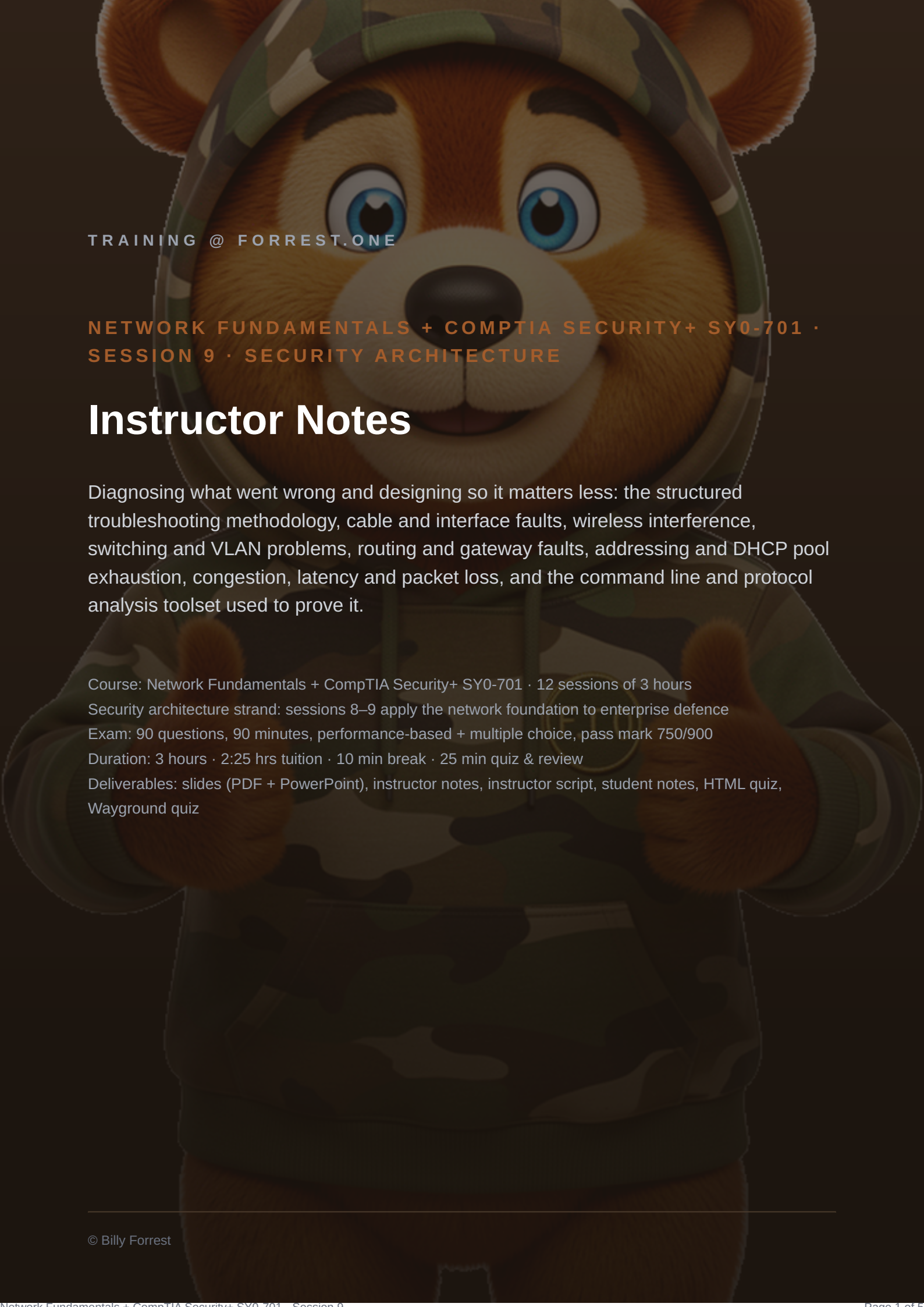




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 9 · SECURITY ARCHITECTURE

Instructor Notes

Diagnosing what went wrong and designing so it matters less: the structured troubleshooting methodology, cable and interface faults, wireless interference, switching and VLAN problems, routing and gateway faults, addressing and DHCP pool exhaustion, congestion, latency and packet loss, and the command line and protocol analysis toolset used to prove it.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Security architecture strand: sessions 8–9 apply the network foundation to enterprise defence

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes — Endpoint, Application, Cloud & Virtualisation Security

A 3-hour delivery guide for Session 9. The session has three movements: harden the host, secure the code, defend the shared estate. Keep the asset-first mindset; for each asset, name the control. The activities fix the attack classifications and the responsibility line.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:15	Welcome & objectives	1–3	Asset-first mindset; objectives
0:15–0:55	Endpoint security	4–8	Protection stack, hardening, MDM; activity
0:55–1:10	OS security & discussion	9–10	Accounts, secure boot, encryption
1:10–1:20	Break	11	10-minute break
1:20–1:55	SDLC & secure coding	12–14	Shift left, DevSecOps, injection
1:55–2:20	Application attacks	15–17	XSS, CSRF, more attacks; activity
2:20–2:40	Cloud & virtualisation	18–21	Models, responsibility, misconfiguration
2:40–3:00	Quiz & close	22–25	Quiz; takeaways; preview

Materials and preparation

- Projector or screen with the Session 9 slide deck (02_Slides.pdf or 02_Slides.pptx).
- One computer or tablet per pair for Quiz_Session_09.html (any browser, no internet required).
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard for the responsibility-line diagram (slide 19).

- Optional: a sandboxed environment to demo a parameterised query fix.

Delivery guidance by slide

Slides 1–3 · Welcome (15 minutes)

Set the asset-first mindset: network (session 8), now hosts, code and cloud. Every asset gets controls. The exam asks you to pick the control for the asset; this session builds that muscle.

Slides 4–8 · Endpoint security (40 minutes)

The protection stack is the anchor: AV/EDR, hardening, patching, app control. Allowlisting versus blocklisting is a direct exam distinction. Hardening draws on CIS benchmarks and vendor guides; frame it as reducing the attack surface by disabling unused services, ports and default accounts. MDM and BYOD need the container story, work and personal data separated, plus application vetting before install. The activity fixes the fleet reasoning.

Activity (slide 8)

Allowlisting stops unknown executables; MDM with containers fits BYOD; guest/IoT devices stay off the domain; patching is the baseline control every endpoint needs. Exam angle: the question 'which control stops an unknown executable' tests allowlisting, not signature updates.

Slides 9–10 · OS security & discussion (15 minutes)

Least privilege, secure boot and full disk encryption are the OS-level controls; add firmware updates, which candidates often forget. The discussion (slide 10) lands the layered-detection argument: AV alone misses unknown threats.

Discussion prompt (slide 10)

AV never fired yet the workstation was compromised. Signatures miss unknown threats, so behaviour monitoring, allowlisting and patching would have caught or prevented it. Detection is a stack, not a product. Prompt for depth: which data state, at rest, in transit or in use, went unprotected on the workstation?

Slides 12–14 · SDLC & secure coding (35 minutes)

Shift left is the theme: security in design, not at the end. Threat modelling before code, review at every change, SAST for source and DAST for running apps. Add secure-coding practices: code runs with least privilege, error handling that leaks nothing, and input validation using whitelisting, sanitisation and boundary checks. DevSecOps puts security in the pipeline and covers infrastructure as code. SQL injection gets the most time; parameterised queries are the fix.

Slides 15–17 · Application attacks (25 minutes)

XSS versus CSRF is the classic confusion: XSS hijacks the browser, CSRF hijacks the action. Mention the Web Application Firewall as a defence that filters and monitors web traffic. Cover buffer overflow, directory

traversal and race conditions, then sandboxing to contain compromised code, then the activity classifies them all.

Activity (slide 17)

' OR 1=1 is SQL injection; a script tag in another user's browser is XSS; a forged form submission on a logged-in session is CSRF. Parameterised queries and output encoding cover most of these. Exam angle: the question may present the symptom and ask for the fix, so match the attack to the countermeasure.

Slides 18–21 · Cloud & virtualisation (20 minutes)

The service model table and the shared responsibility line are the exam core. Frame the line with deployment models too: public, private, hybrid and community shift who secures what. Misconfiguration is the number one cloud risk, CASB and posture management are the tools, and infrastructure as code needs template scanning and central secrets management. Virtualisation: the hypervisor is the crown jewel, VM escape is the nightmare, containers share the kernel and need namespaces and seccomp.

Slides 22–25 · Quiz & close (20 minutes)

Run the quiz, review low scores, walk the takeaways and assign the checklist. Preview Session 10, vulnerability management, resiliency and asset protection.

Common misconceptions and corrections

Misconception	Correction
"Antivirus is enough"	Signatures miss unknown threats, so layer AV/EDR with patching and app control
"Blocklisting is the best app control"	Allowlisting wins; blocklists miss unknown malware
"XSS and CSRF are the same"	XSS runs scripts in a browser; CSRF forges actions on a session
"Input validation is optional for trusted fields"	Every input field is a potential injection point; whitelist, sanitise and bound it
"The cloud vendor secures everything"	Shared responsibility; you secure what is in the cloud
"Private cloud has no shared responsibility"	Even private cloud shares duties, typically physical security, with the provider
"All hypervisors are equally secure"	Type 1 bare metal has a smaller attack surface than a hosted Type 2
"Containers are perfectly isolated"	Containers share the kernel; isolation needs namespaces and seccomp
"Security testing happens at release"	Shift left; test in the pipeline, not at the gate

Assessment check

- Session objectives map to topic areas 9A–9D and the security-architecture strand.
- The HTML quiz tags every question with its topic area for traceable revision.
- The Wayground quiz (15 questions) gives an in-class, importable assessment of the same topics.